

C 题:安全与否?

你大概听说过计算机黑客和计算机病毒。除非你的计算机遭到过黑客或病毒的攻击你或许不知道它们能怎样影响个人或机构的。如果一台计算机受到黑客或者病毒攻击，那么其中重要的个人信息和软件就有可能丢失。

正在考虑创建一所新的大学校园，你们的任务是对这所大学的信息技术（IT）安全性的风险评估建立模型。下面的叙述给出了一些背景材料以帮助你形成有关检验 IT 安全性的方案。明确的任务将在后面给出。

通过多个防御层来防止计算机系统遭受恶意活动的攻击。包括政策层和技术层（图 1，预防性的防御措施(略)）两者在内的这些防御层将会对机构的风险类型产生各种不同的影响(图 2, IT 系统经济风险的示意图(略))。

管理和使用方面的政策处理用户怎样和机构的计算机和网络相互作用以及员工（系统管理员）怎样维护网络。这些政策可以包括密码验证，正式的安全审核，使用跟踪，无线设备的使用，有关可移动媒体的关注，个人应用的限制和用户培训。一种实例性的密码政策可以包括对密码的长度和密码所用字母的要求，更改密码的频率以及允许登录错误的次数。每一个政策方案都包含与其执行相关联的直接的费用以及影响到生产效率和安全性因素。在图 1 中，只对最高层面作了详细说明，其实每个层面的结构都是同样的。

安全状况的第二个方面就是检测、减轻和挫败来自内部和外部两方面用户的未经授权的活动的一组技术方案。这些技术方案涵盖了软件和硬件两个方面，还包括入侵检测系统(IDS = Intrusion Detection Systems)，防火墙，防病毒系统，易受攻击的扫描仪和冗余备份等。比如说，IDS 监视并记录某一特定计算机或来自具有调查数据并能提供识别可疑活动“犯罪之后”的侦破能力的网络上的重要事件。SNORT(www.snort.org)是一个广受欢迎的 IDS 方案。图 1 提供了一个关键防御措施的样本(管理/使用的政策和技术解决方案)。和政策一样，技术解决方案也有其直接的费用以及影响到生产效率和安全性因素。

To Be Secure or Not to Be?

You probably know about computer hackers and computer viruses. Unless your computer has been targeted by one, you may not know how they could affect an individual or an organization. If a computer is attacked by a hacker or virus, it could lose important personal information and software. The creation of a new university campus is being considered. Your requirement is to model the risk assessment of information technology (IT) security for this proposed university. The narrative below provides some background to help develop a framework to examine IT security. Specific tasks are provided at the end of this narrative.

Computer systems are protected from malicious activity through multiple layers of defenses. These defenses, including both policies and technologies (Figure 1 Preventative Defensive Measures), have varying effects on the organization's risk categories (Figure 2 Economic Risk Schematic for IT Systems).

Management and usage policies address how users interact with the organization's computers and networks and how people (system administrators) maintain the network. Policies may include password requirements, formal security audits, usage tracking, wireless device usage, removable media concerns, personal use limitations, and user training. An example password policy would include requirements for the length and characters used in the password, how frequently they must be changed, and the number of failed login attempts allowed. Each policy solution has direct costs associated with its implementation and factors that impact productivity and security. In Figure 1, only the topmost branch is fully detailed. The structure is replicated for each branch.

The second aspect of a security posture is the set of technological solutions employed to detect, mitigate, and defeat unauthorized activity from both internal and external users. Technology solutions cover both software and hardware and include intrusion detection systems (IDS), firewalls, anti-virus systems, vulnerability scanners, and redundancy. As an example, IDS monitors and records significant events on a specific computer or from the network examining data and providing an "after the fact" forensic ability to identify suspect activity. SNORT (www.snort.org) is a popular IDS solution. Figure 1 provides a sample of key defensive measures (management/usage policies and technology solutions). As with a policy, a technology solution also has direct costs, as well as factors that impact productivity and security.

信息安全风险的来源包括(但并不限于)机构内部或者外部的人或硬件(图2)。不同的预防性防御措施(图1)可能在防御内部威胁比防御来自计算机黑客的威胁更有效。另外,外部威胁的动机往往不同,这也可能需要不同的安全措施。比如说,对付一个正试图检索私人数据或客户数据库的入侵者和对付一个正试图瘫痪网络的入侵者很可能要采取极不同的斗法。

属于机构可能要面对信息安全方面的潜在费用包括机会成本(图2)(校注:企业管理当局没有作出一项决策或未能利用一个能带来更多收益的机会(例如投资项

目), 失去的收益就是机会成本)、 人员费用和预防性防御措施的费用。重要的机会成本主要包括: 诉讼的赔偿金, 私人数据的丢失, 消费者的信心, 直接收入的丢失, 重建数据, 重建服务。每种花费 根据机构规模的不同而不同。比如说, 大学的卫生保健院由于在应诉、病人医疗记录可用性方面的损失比之于重建服务系统需要更大的潜在费用。

机构可以通过风险分析来评价潜在的机会成本。风险可以被分成三个风险类型: 机密性, 完整性和可用性。组合起来, 这些分类确定了机构的安全状况。每种风险类型都会对取决于机构的任务和要求的费用产生影响。机密性指的是保护数据不向未经授权的访问者公开。如果卫生保健院的记录数据因疏忽而被公开或者被盗, 那么该院可能面临严重的诉讼。数据的完整性是指数据的状态不被改变。如果入侵者修改了某些产品的定价信息或者删除了全部的数据集, 机构将会面临的代价是: 与改正由于受错误数据影响的交易相关联的费用、与重新建立正确价值相关联的费用以及消费者信心以及收入方面的可能的损失。最后, 可用性是指包括数据和服务的资源对授权用户的可利用的。这种风险可以用和机密性、完整性类似的方式从财政上表明自己。

为增加机构安全状况所执行的每一种措施都会(正面或反面地)影响到这三种风险类型。每当实施一种新的防御安全措施时, 它将会改变当前的安全状况以及紧随其后的潜在的机会成本。机构所面临的一个复杂的问题是怎样在他们的潜在的机会成本对保护其 IT 基本设施(预防性的保护措施) 费用的平衡。

Sources of risk to information security include, but are not limited to, people or hardware within or outside the organization (Figure 2). Different preventive defensive measures (Figure 1) may be more effective against an insider threat than a threat from a computer hacker. Additionally, an external threat may vary in motivation, which could also indicate different security measures. For example, an intruder who is trying to retrieve proprietary data or customer databases probably should be combated much differently from an intruder who is trying to shut down a network.

Potential costs due to information security that an organization may face (Figure 2) include opportunity cost, people, and the cost of preventative defensive measures.

Significant opportunity costs include: litigation damages, loss of proprietary data, consumer confidence, loss of direct revenue, reconstruction of data, and reconstruction of services. Each cost varies based on the profile of the organization.

For example, a health care component of the university might have a greater potential for loss due to litigation or availability of patient medical records than with reconstruction of services.

An organization can evaluate potential opportunity costs through a risk analysis. Risks can be broken down into three risk categories; *confidentiality*, *integrity*, and *availability*. Combined, these categories define the organization's security posture.

Each of the categories has different impacts on cost depending on the mission and requirements of the organization. *Confidentiality* refers to the protection of data from release to sources that are not authorized with access. A health care organization

could face significant litigation if health care records were inadvertently released or stolen. The *integrity* of the data refers to the unaltered state of the data. If an intruder modifies pricing information for certain products or deletes entire data sets, an organization would face costs associated with correcting transactions affected by the erroneous data, the costs associated with reconstructing the correct values, and possible loss of consumer confidence and revenue. Finally, *availability* refers to resources being available to an authorized user, including both data and services. This risk can manifest itself financially in a similar manner as confidentiality and integrity. Each measure implemented to increase the security posture of an organization will impact each of the three risk categories (either positively or negatively). As each new defensive security measure is implemented, it will change the current security posture and subsequently the potential opportunity costs. A complicated problem faced by organizations is how to balance their potential opportunity costs against the expense of securing their IT infrastructure (preventative defensive measures).

任务 1: Rite-On 咨询公司交给你们的任务是要研制一个模型, 该模型可以用来确定一所新大学适当的 IT 安全水平所需要的正确的政策和技术增强。当要申请开张一所新大学时的即刻需要是确定能使和采购、维护与系统管理员的培训等各项费用一起极小化机会成本的各种预防性防御措施的最佳组合。Rite-On 签约了一批技术人员去搜集用来支持 IT 安全规划的当前的技术规范。一些可能采取的防御措施编目的详细技术数据包含在附件中的表格 A 与表格 B 中。

准备这些数据表的技术人员提示说, 当你组合这些防御措施时, 在机密性、完整性和可用性及其相互之间的累积效应不能只是简单的相加。

打算新建的大学系统有 10 个学术系, 一个校际体育部, 一个招生办公室, 一家书店, 一个教务办公室(成绩和学术状况管理), 一个可容纳 15,000 名学生的综合宿舍楼。大学预期有 600 名职员和教员(不包括 IT 支持人员)来完成日常的工作。学术系将维护 21 个计算机实验室(每个实验室有 30 台计算机)以及 600 名职员和教员所使用的计算机(每个雇员一台计算机)。宿舍中的每个房间配备两个可以高速接入校园网的接

口。预计每个学生都将有一台计算机。其他部门/机构所需的计算机数量现时还无法预测。已知书店将有一个 WEB 站点并能提供网上售书服务，教务办公室将维护一个 WEB 站点便于学生可以查询付费情况和成绩。另外，行政办公室、学生健康中心和体育部也将各自维护一个 WEB 站点。

行政人员的平均年薪为\$38,000，教员的平均年薪为\$77,000。当前的行业通常认为，管理每个局域网需要雇佣 3 到 4 个系统管理员，另外，每 300 台计算机需要雇佣 1 个系统管理员（桌面支持）。另外，(WEB 主机或者数据管理系统的)每个独立的计算机系统一般也是由 1 名系统管理员来管理的。

表 1 列出了当前没有防御措施的 IT 机会成本的预测。各种不同风险类型 (C 表示机密性、I 表示完整性而 A 表示可用性)在给定成本中所占的比例也在表 1 给出。

Task 1: You have been tasked by the Rite-On Consulting Firm to develop a model that can be used to determine an appropriate policy and the technology enhancements for the proper level of IT security within a new university campus. The immediate need is to determine an optimal mix of preventive defensive measures that minimizes the potential opportunity costs along with the procurement, maintenance, and system administrator training costs as they apply to the opening of a new private university. Rite-On contracted technicians to collect technical specifications on current technologies used to support IT security programs. Detailed technical data sheets that catalog *some* possible defensive measures are contained in Enclosures A and B. The technician who prepared the data sheets noted that as you combine defensive measures, the cumulative effects within and between the categories confidentiality, integrity, and availability cannot just be added.

The proposed university system has 10 academic departments, a department of intercollegiate athletics, an admissions office, a bookstore, a registrar's office (grade and academic status management), and a dormitory complex capable of housing 15,000 students. The university expects to have 600 staff and faculty (non IT support) supporting the daily mission. The academic departments will maintain 21 computer labs with 30 computers per lab, and 600 staff and faculty computers (one per employee). Each dorm room is equipped with two (2) high speed connections to the university network. It is anticipated that each student will have a computer. The total computer requirements for the remaining department/agencies cannot be anticipated at this time. It is known that the bookstore will have a Web site and the ability to sell books online. The Registrar's office will maintain a Web site where students can check the status of payments and grades. The admissions office, student health center, and the athletic department will maintain Web sites.

The average administrative employee earns \$38,000 per year and the average faculty employee earns \$77,000 per year. Current industry practice employs three to four system administrators (sys admin) per sub-network and there is typically one (1) sys admin (help desk support) employee per 300 computers. Additionally, each separate system of computers (for web hosting or data management) is typically managed by one (1) sys admin person.

The current opportunity cost projection (due to IT) with no defensive measures is shown in Table 1. The contribution of various risk categories (Confidentiality Integrity, and Availability) to a given cost is also shown in Table 1.

任务 2：我们知道技术性的规范随时间变化很快。但费用，风险类型和风险的来源之间的关系和相互影响的变化则比较慢一些。请针对任务 1 中的问题建立一个模型，并使得这个模型有足够的灵活性，既可以适应技术能力的迅速变化，又可以移植应用于不同的机构。精心描述你在设计模型时所做的假设。另外，提供一个例子说明大学怎样利用你的模型来确定其最初的 IT 安全系统并定期对它进行更新。

任务 3：为大学校长准备一个 3 页左右的描述你在任务 2 中所建模型的优点、弱点和灵活性的立场声明。另外，解释一下从你的模型能推断什么以及不应该推断什么。

任务 4：如果你为一家提供 WWW 搜索引擎的商业公司(例如 Google,

Yahoo, AltaVista, ...)建立 IT 安全模型，解释两者在初始风险类型贡献方面(表 1)可能存在的差异。你为大学建立的模型同样适用于这些商业性公司吗？

任务 5: Honeynets 是为搜集广泛的 IT 安全威胁信息而设计的。给你的主管写一份两页的备忘录对大学或者搜索引擎公司是否应该考虑使用 honeynet 提出建议。(校注: Honeynet Project 是一个由献身于信息安全的安全专业人员的非盈利性研究组织。它创建于 1999 年 4 月，其全部工作就是开放资源(OpenSource)并与安全界共享。)

任务 6: 要想成为一个 IT 安全咨询方面的领导者，Rite-On 咨询公司必须能够有效地预见到信息技术的未来发展方向，并能够向其他公司提出如何应对未来信息安全风险的建议。在完成你的分析之后，为 Rite-On 咨询公司的总裁写一份两页的备忘录，告诉他信息安全的未来。另外，描述一下怎样用你的模型来预测和应对不确定的未来。

[注：原题中的图 1、图 2 和附录 1、附录 2 略]

Task 2: We know that technical specifications will change rapidly over time. However, the relations and interplay among costs, risk categories, and sources of risk will tend to change more slowly. Create a model for the problem in Task 1 that is flexible enough to adapt to changing technological capabilities and can be applied to different organizations. Carefully describe the assumptions that you make in designing the model. In addition, provide an example of how the university will be able to use your model to initially determine and then periodically update their IT security system.

Task 3: Prepare a three page position paper to the university President that describes the strengths, weakness, and flexibility of your model in Task 2. In addition, explain what can be inferred and what should not be inferred from your model.

Task 4: Explain the differences that may exist in the initial Risk Category Contributions (Table 1) if you model IT security for a commercial company that provides a search engine for the World Wide Web (such as Google, Yahoo,

AltaVista, ...). Will your model work for this type of organization?

Task 5: Honeynets are designed to gather extensive information on IT security threats. Write a two-page memo to your supervisor advising whether a university or a search engine company should consider using a honeynet.

Task 6: To become a leader in IT security consulting, Rite-On Consulting must also take an active role in anticipating the future direction of information technology and advising companies on how to respond to future security risks. After performing your analysis, write a two-page memo to the President of Rite-On to inform him of the future of IT security. In addition, describe how your model can be used to anticipate and respond to the uncertain future.

[Attention: Figures 1-2 and Appendices 1-2 are Omitted here]